

ISO/IEC 27001 ומשפחת תקני ISO/IEC

27000 – ספר סיכום

ספר סיכום מקיף בעברית על תקן **ISO/IEC 27001** (ניהול אבטחת מידע), על מבנהו, נספח הבקורות שלו, תהליך ההסמכה, ועל **התקנים הנגזרים** ממשפחת ISO/IEC 27000 – כולל תקנים ייעודיים לענן, לפרטיות, לאבטחת סייבר, לניהול אירועים ועוד.

הספר נכתב כחומר לימוד/עיון למקצועני אבטחת מידע, מנהלי סיכונים, מבקרים פנימיים, ואנשי מקצוע המובילים תהליכי הטמעה או הסמכה בארגון.

הבהרה: מסמך זה הוא סיכום לימודי ואינו תחליף לרכישת נוסח התקן הרשמי מ-ISO/IEC, ואינו ייעוץ משפטי או רגולטורי. לפני הטמעה או הסמכה בפועל יש להיעזר בנוסח התקן המלא ובגורם מקצועי מוסמך (יועץ/מבקר/גוף הסמכה מוכר).

גרסת PDF: כל הספר (כל הפרקים + נספח הכלים) מאוחד גם לקובץ יחיד – **ISO-27001-Summary-Book-HE.pdf**. הפקה מחדש לאחר עדכון פרק: `python3 tools/build_book_pdf.py` (ראו [tools/README.md](https://github.com/0x00sec/ISO-27001-Summary-Book-HE/blob/main/tools/README.md)).

תוכן העניינים

#	פרק	תיאור קצר
1	מבוא ומשפחת התקנים	מהי אבטחת מידע, מהו ISMS, רקע היסטורי, מבנה משפחת ISO/IEC 27000
2	מבנה התקן ISO/IEC 27001	סעיפים 4-10, מבנה PDCA, Annex SL, הקשר ארגוני, מנהיגות, תכנון, תמיכה, תפעול, הערכה, שיפור
3	נספח A – בקורות אבטחת מידע	93 הבקורות (מהדורת 2022) ב-4 קטגוריות: ארגוניות, אנשים, פיזיות, טכנולוגיות
4	תקנים נגזרים ממשפחת ISO/IEC 27000	27002, 27005, 27017, 27018, 27701, 27032, 27035, 27036, 22301 ועוד
5	תהליך ההסמכה והביקורת	שלבי הסמכה, ביקורת Stage 1/Stage 2, ביקורות מעקב, גופי הסמכה
6	יישום מעשי בארגון	מפת דרכים להטמעה, הערכת סיכונים, SoA, מדדים, תרבות אבטחה
7	2013 מול 2022 – מה השתנה	ההבדלים המרכזיים בין המהדורות, השלכות על ארגונים מוסמכים
8	מילון מונחים ורשימת בדיקה	מונחי מפתח + Checklist מעשי להטמעה/הסמכה
9	בדיקות חדירה (Penetration Testing) ו-ISO/IEC 27001	מיפוי pentest לבקורות נספח A, סוגי בדיקות ומתודולוגיות, ROE ואתיקה, דוגמה עובדת שממירה ממצאי pentest אמיתיים מהריפו הזה לרשומת סיכונים, וסדר עדיפויות מומלץ בזמן מוגבל

כלי נלווה: מחשבון סקר סיכונים לפי CWE

בתיקית [tools/](#) נמצא כלי שורת-פקודה אופליין (`cwe_risk_calculator.py`) שממחיש כיצד הופכים ממצאי חולשות טכניות (ממופות למזחי **CWE**) לרשומת סיכונים מדורגת, לפי מודל Likelihood × Impact בהתאם למתודולוגיית ISO/IEC 27005 — ראו התייחסות מפורטת בפרק 6 (6.3) ודוגמה מבוססת-pentest אמיתי בפרק 9 (9.6).

איך לקרוא את הספר

- אם אתם חדשים לנושא — התחילו מפרק 1 והתקדמו לפי הסדר.
- אם אתם כבר מכירים את התקן ומחפשים רענון על הבקורות — קפצו ישירות לפרק 3.
- אם אתכם מעניינים תקנים ספציפיים (ענן, פרטיות, המשכיות עסקית) — פרק 4.
- אם אתם מתכננים להסמכה בפועל — פרקים 5-6 ו-8 (ה-Checklist) הם החומר המעשי.

פרק 1: מבוא ומשפחת התקנים

1.1 מהי אבטחת מידע ומהי ISMS

אבטחת מידע (Information Security) עוסקת בהגנה על מידע מפני איומים, כדי להבטיח שלושה מאפיינים מרכזיים — המכונים **משולש ה-CIA**:

- **Confidentiality (סודיות)** — המידע נגיש רק למי שמורשה לגשת אליו.
- **Integrity (שלמות)** — המידע מדויק, שלם, ולא שונה ללא הרשאה.
- **Availability (זמינות)** — המידע והמערכות זמינים למי שזקוק להם, כשהוא זקוק להם.

תקנים מודרניים (כולל ISO/IEC 27001:2022) מוסיפים לעיתים גם מאפיינים כמו **אותנטיות (Authenticity)**, **אחריות (Accountability)**, **אי-התכחשות (Non-repudiation)** ו**אמינות (Reliability)**.

ISMS — Information Security Management System (מערכת ניהול אבטחת מידע)

היא לא "מוצר" או "מערכת טכנולוגית" אחת, אלא **מערכת ניהולית**: מדיניות, תהליכים, נהלים, תפקידים, אחריות, ומשאבים שהארגון מפעיל באופן שיטתי ומתמשך כדי לנהל את הסיכונים לאבטחת המידע שלו. זהו ההבדל המרכזי בין "יש לנו פיירוול וסיסמאות חזקות" לבין "יש לנו ISMS" — הראשון הוא אוסף בקורות נקודתיות, השני הוא מערכת ניהול שיטתית שמתעדכנת, נמדדת, ומשתפרת לאורך זמן.

1.2 רקע היסטורי

- **BS 7799 (1995)** — תקן בריטי (BSI) שהיה הבסיס למה שיהפוך מאוחר יותר לתקן הבינלאומי. חלק 1 (Code of Practice) וחלק 2 (Specification for ISMS).
- **ISO/IEC 17799 (2000)** — אימוץ בינלאומי של BS 7799 Part 1 כקוד התנהגות לבקורות אבטחת מידע.
- **BS 7799-2:2002** — עדכון חלק 2 (דרישות ל-ISMS) שכלל את מודל ה-PDCA (Plan-Do-Check-Act) של דמינג.
- **ISO/IEC 27001:2005** — הפרסום הבינלאומי הראשון של תקן הדרישות עצמו, מבוסס על BS 7799-2:2002. זהו ה"לידה" הרשמית של משפחת 27000.
- **ISO/IEC 27002:2005** — שינוי שם ל-ISO/IEC 17799:2005 (קוד ההתנהגות לבקורות), שקיבל מספור מחדש כ-27002 ב-2007 כדי להתאים למשפחה.
- **ISO/IEC 27001:2013** — עדכון מהותי: מעבר למבנה האחיד **Annex SL** המשותף לכל תקני מערכות הניהול של ISO (למשל ISO 9001, ISO 14001), עדכון נספח A ל-114 בקורות ב-14 קטגוריות (domains).
- **ISO/IEC 27001:2022** — המהדורה הנוכחית. הדרישות עצמן (סעיפים 4-10) עודכנו בעדכונים נקודתיים, אך השינוי הבולט ביותר הוא **ריענון מלא של נספח A**: מ-114 בקורות ב-14 קטגוריות

ל-93 בקורות ב-4 קטגוריות (ארגוניות, אנשים, פיזיות, טכנולוגיות), בהתאמה לפרסום המקביל של ISO/IEC 27002:2022.

1.3 מבנה משפחת ISO/IEC 27000

משפחת ISO/IEC 27000 היא אוסף תקנים שכולם עוסקים בהיבטים שונים של ניהול אבטחת מידע, ובנויים סביב "גרעין" משותף — **ISO/IEC 27001** (הדרישות שאפשר להיסמך עליהן) ו-**ISO/IEC 27002** (קטלוג הבקורות המפורט). שאר התקנים במשפחה הם:

- **תקני תמיכה כלליים** — מדריכי יישום, מדידה, ביקורת, ניהול סיכונים.
- **תקני מגזר** — התאמות התקן לתעשיות ספציפיות (בריאות, אנרגיה, טלקום, ענן).
- **תקני נושא** — העמקה בנושא ספציפי (פרטיות, סייבר, פורנזיקה דיגיטלית, ניהול אירועים, יחסי ספקים).

חשוב להבין: רק **ISO/IEC 27001** הוא תקן "הניתן להסמכה" (**certifiable**) — כלומר ארגון יכול לעבור ביקורת של גוף הסמכה חיצוני ולקבל תעודת התאמה רשמית לתקן זה. כל שאר התקנים במשפחה הם **תקני הנחיה (guidance)** — הם עוזרים ליישם, להעמיק, או להרחיב את ה-ISMS, אך אין "תעודת ISO 27002" או "תעודת ISO 27005" במובן הפורמלי (למעט חריגים כמו ISO/IEC 27701, שניתן להסמיק אליו כתוספת ל-27001, וכן PIMS/PIPS extension). פירוט מלא של התקנים הנגזרים נמצא בפרק 4.

1.4 מודל Annex SL ו-PDCA

מאז מהדורת 2013, ISO/IEC 27001 בנוי לפי **Annex SL** (High Level Structure) — מבנה אחיד עם 10 סעיפים המשותף לכל תקני מערכות הניהול של ISO. המשמעות המעשית: ארגון שכבר מיישם ISO 9001 (איכות) או ISO 14001 (סביבה) ימצא מבנה מוכר ויוכל לשלב (Integrated Management System) בין המערכות בקלות יחסית.

המודל התפעולי הבסיסי הוא **PDCA — Plan, Do, Check, Act**:

1. **Plan (תכנון)** — הגדרת היקף ה-ISMS, מדיניות, הערכת סיכונים, תכנית טיפול בסיכונים.
2. **Do (ביצוע)** — יישום הבקורות והתהליכים שהוחלט עליהם.
3. **Check (בדיקה)** — ניטור, מדידה, ביקורות פנימיות, סקר הנהלה.
4. **Act (שיפור)** — טיפול באי-התאמות, פעולות מתקנות, שיפור מתמשך.

מחזור זה **אינו חד-פעמי** — הוא לב ליבו של הרעיון ש-ISMS הוא מערכת חיה ומתמשכת, ולא פרויקט עם קו סיום.

פרק 2: מבנה התקן ISO/IEC 27001

תקן ISO/IEC 27001 מחולק לשני חלקים עיקריים:

1. **הגוף הראשי (סעיפים 4-10)** — הדרישות שארגון **חייב** לעמוד בהן כדי להיות מוסמך. אלו דרישות "לא ניתנות למיקוח" (must), בשונה מהבקורות בנספח A שניתן להחריג בהתאם להערכת סיכונים ול-SoA.
2. **נספח A** — קטלוג בקורות אבטחת מידע (מפורט בפרק 3), שמשמש כ"רשימת קניות" שממנה הארגון בוחר אילו בקורות רלוונטיות לו, בהתבסס על תוצאות הערכת הסיכונים.

סעיף 4 — הקשר הארגוני (Context of the Organization)

- **4.1 הבנת הארגון והקשרו** — זיהוי סוגיות פנימיות וחיצוניות הרלוונטיות למטרת הארגון ולמסוגלותו להשיג את התוצאות הצפויות מה-ISMS (למשל: רגולציה, תחרות, טכנולוגיה, תרבות ארגונית).
- **4.2 הבנת הצרכים והציפיות של בעלי עניין** — לקוחות, רגולטורים, עובדים, ספקים, בעלי מניות — ואילו מהדרישות שלהם רלוונטיות ל-ISMS (כולל דרישות חוזיות ורגולטוריות כמו GDPR, חוק הגנת הפרטיות הישראלי, PCI DSS וכו').
- **4.3 קביעת היקף ה-ISMS (Scope)** — הגדרה מדויקת אילו יחידות ארגוניות, מיקומים, נכסים וטכנולוגיות נכללים ב-ISMS. ההיקף חייב להיות מתועד וזמין כמידע מתועד. **זהו אחד הסעיפים הקריטיים ביותר** — היקף מוגדר בצורה רופפת או רחבה מדי מסבך את ההטמעה וההסמכה.
- **4.4 מערכת ניהול אבטחת המידע** — דרישה כללית להקים, ליישם, לתחזק ולשפר באופן מתמשך ISMS בהתאם לדרישות התקן.

סעיף 5 — מנהיגות (Leadership)

- **5.1 מנהיגות ומחויבות** — ההנהלה הבכירה (Top Management) חייבת להפגין מחויבות פעילה: הבטחת התאמת מדיניות אבטחת המידע לכיוון האסטרטגי, הקצאת משאבים, קידום שיפור מתמשך, ותמיכה בתפקידים רלוונטיים.
- **5.2 מדיניות** — קביעת מדיניות אבטחת מידע מתועדת, מותאמת למטרת הארגון, כוללת מחויבות לעמידה בדרישות ולשיפור מתמשך.
- **5.3 תפקידים, אחריות וסמכויות ארגוניות** — הקצאה ותקשור ברורים של אחריות ל-ISMS (למשל CISO, בעלי נכסים/Asset Owners, בעלי סיכונים/Risk Owners).

סעיף 6 — תכנון (Planning)

- **6.1.1 טיפול בסיכונים והזדמנויות (כללי)** — תכנון פעולות להתמודדות עם סיכונים והזדמנויות שזוהו בסעיף 4.1-4.2.

- **6.1.2 הערכת סיכוני אבטחת מידע (Risk Assessment)** — קביעת מתודולוגיה עקבית וניתנת לחזרה להערכת סיכונים: זיהוי סיכונים, בעלי סיכונים, ניתוח (סבירות x השפעה), והערכה מול קריטריוני קבלת סיכון.
- **6.1.3 טיפול בסיכוני אבטחת מידע (Risk Treatment)** — בחירת אפשרויות טיפול (הפחתה, העברה, הימנעות, קבלה), בחירת בקורות מתוך נספח A (או מקורות אחרים), והפקת **הצהרת ההתאמה (Statement of Applicability – SoA)** — מסמך מפתח שמפרט אילו מ-93 הבקורות נבחרו, אילו הוחרגו ומדוע, ואיך כל בקרה מיושמת.
- **6.2 יעדי אבטחת מידע ותכנון להשגתם** — יעדים מדידים (SMART ככל האפשר), מתועדים, ומתוקשרים, עם תכנית ברורה: מה ייעשה, אילו משאבים, מי אחראי, מתי, ואיך יוערכו התוצאות.
- **6.3 תכנון שינויים** (נוסף במהדורת 2022) — כשה-ISMS זקוק לשינוי (מבני, היקפי, תהליכי), השינוי חייב להתבצע באופן מתוכנן ומבוקר.

סעיף 7 — תמיכה (Support)

- **7.1 משאבים** — הקצאת משאבים (אנשים, תקציב, תשתית, זמן) המספיקים להקמה, יישום, תחזוקה ושיפור מתמשך של ה-ISMS.
- **7.2 מיומנות (Competence)** — הבטחת שאנשים העובדים תחת שליטת הארגון מיומנים (השכלה, הכשרה, ניסיון) לתפקידם באבטחת מידע, כולל שמירת עדות מתועדת.
- **7.3 מודעות (Awareness)** — עובדים מודעים למדיניות אבטחת המידע, לתרומתם לאפקטיביות ה-ISMS, ולהשלכות אי-עמידה בדרישות.
- **7.4 תקשורת** — קביעת מתי, עם מי, איך, ומי מתקשר בנוגע לענייני ISMS — פנימית וחיצונית.
- **7.5 מידע מתועד (Documented Information)** — דרישות ליצירה, עדכון, ובקרה של מסמכי ה-ISMS: גרסאות, אישורים, זמינות, הגנה מפני אובדן/שימוש לא נאות.

סעיף 8 — תפעול (Operation)

- **8.1 תכנון ובקרה תפעולית** — יישום בפועל של התכניות מסעיף 6: תהליכים, קריטריונים לביצוע, בקרה על שינויים מתוכננים, סקירת השלכות של שינויים לא מתוכננים.
- **8.2 הערכת סיכוני אבטחת מידע** — ביצוע הערכות סיכונים בפרקי זמן מתוכננים או כאשר מתרחשים שינויים משמעותיים.
- **8.3 טיפול בסיכוני אבטחת מידע** — יישום תכנית הטיפול בסיכונים ושמירת עדות לתוצאות.

סעיף 9 — הערכת ביצועים (Performance Evaluation)

- **9.1 ניטור, מדידה, ניתוח והערכה** — קביעה מה יימדד, איך, מתי, ומי מנתח ומעריך את התוצאות (מדדי KPI לאבטחת מידע).
- **9.2 ביקורת פנימית (Internal Audit)** — תכנית ביקורות בפרקי זמן מתוכננים לבדיקה שה-ISMS תואם לדרישות התקן ולדרישות הארגון עצמו, ושהוא מיושם ומתוחזק באפקטיביות. הביקורת חייבת להיות אובייקטיבית ובלתי-משוחדת (מבקר לא מבקר את תחום עבודתו שלו).

• **9.3 סקר הנהלה (Management Review)** — ההנהלה הבכירה סוקרת את ה-ISMS בפרקי זמן מתוכננים (בד"כ שנתי לפחות), בוחנת קלט (תוצאות ביקורות, משוב מבעלי עניין, שינויי סיכונים, הזדמנויות לשיפור) ומפיקה החלטות ופעולות.

סעיף 10 — שיפור (Improvement)

• **10.1 שיפור מתמשך** — שיפור מתמיד של התאמת, נאותות ואפקטיביות ה-ISMS (נוסח שהתעדכן ב-2022 והפך תמציתי יותר).

• **10.2 אי-התאמה ופעולה מתקנת** — כאשר מתגלה אי-התאמה (Nonconformity), הארגון חייב להגיב אליה, לנקוט פעולה לתקן ולטפל בהשלכות, להעריך את הצורך בהסרת הסיבה השורשית (Root Cause) כדי שלא תישנה, ליישם כל פעולה נדרשת, ולסקור את אפקטיביות כל פעולה מתקנת.

הערה מתודולוגית: "חייב" מול "לפי הצורך"

ההבחנה בין סעיפים 4-10 (חובה מלאה, ללא אפשרות החרגה) לבין נספח A (רשימת בקורות שממנה בוחרים לפי סיכון) היא אחד הדברים הכי חשוב להבין נכון בתקן — טעות נפוצה היא לחשוב ש"ISO 27001" = "יישום כל 93 הבקורות". בפועל, יישום כל הבקורות בלי הצדקה מבוססת-סיכון הוא בעצמו סימן לחוסר הבנה של רוח התקן, שמבוסס על ניהול סיכונים ולא על צ'ק-ליסט טכני גורף.

פרק 3: נספח A – בקורות אבטחת מידע (מהדורת 2022)

נספח A של ISO/IEC 27001:2022 (התואם, מילה במילה, לגוף הבקורות של ISO/IEC 27002:2022) כולל **93 בקורות**, מאורגנות ב-**4 קטגוריות (themes)** במקום 14 הדומיינים של מהדורת 2013. חשוב לזכור: נספח A הוא **רשימה** לבחירה לפי סיכון – לא כל הבקורות רלוונטיות לכל ארגון, וההחלטה אילו לכלול/להחריג (ועם איזה נימוק) מתועדת ב-**הצהרת ההתאמה (Statement of Applicability, SoA)**.

בנוסף, כל בקרה במהדורת 2022 מתויגת ב-5 סוגי **תכונות (attributes)** שמאפשרים סינון וניתוח חוצה-קטגוריות: סוג הבקרה (מונעת/מגלה/מתקנת), מאפייני אבטחת מידע (סודיות/שלמות/זמינות), מושגי אבטחת סייבר (זיהוי/הגנה/גילוי/ תגובה/התאוששות לפי NIST CSF), יכולות תפעוליות (ממשל, ניהול נכסים, הגנה פיזית וכו'), ותחומי אבטחה (ממשל/אקוסיסטם, הגנה, הגנת מידע, המשכיות).

A.5 – בקורות ארגוניות (37 בקורות)

הקטגוריה הגדולה ביותר, עוסקת במדיניות, ממשל, ניהול סיכונים, נכסים, ספקים ותאימות. בין הבקורות המרכזיות:

#	בקרה
5.1	מדיניות אבטחת מידע ומדיניות ספציפיות לנושא
5.2	תפקידים ואחריות באבטחת מידע
5.3	הפרדת תפקידים (Segregation of Duties)
5.7	מודיעין אימים (Threat Intelligence) – בקרה חדשה ב-2022
5.9	מלאי נכסי מידע ונכסים נלווים
5.10	שימוש מקובל בנכסי מידע
5.12	סיווג מידע
5.15	בקרת גישה
5.16	ניהול זהויות
5.17	מידע לאימות (Authentication Information)
5.23-5.19	אבטחת מידע ביחסי ספקים, כולל שירותי ענן (5.23 – חדשה ב-2022)
5.28-5.24	ניהול אירועי אבטחת מידע: תכנון, דיווח, הערכה, תגובה, למידה
5.29	אבטחת מידע בזמן שיבוש (Business Continuity)
5.30	מוכנות טכנולוגית מידע להמשכיות עסקית (ICT readiness) – חדשה ב-2022
5.36-5.31	דרישות משפטיות, רגולטוריות וחוזיות, זכויות קניין רוחני, הגנת פרטיות (PII), סקירת עמידה בדרישות

#	בקרה
5.37	נהלי הפעלה מתועדים

A.6 – בקורות אנשים (8 בקורות)

עוסקות במחזור חיי העובד ובגורם האנושי:

#	בקרה
6.1	בדיקות סינון (Screening) לפני העסקה
6.2	תנאי העסקה
6.3	מודעות, חינוך והכשרה לאבטחת מידע
6.4	תהליך משמעותי
6.5	אחריות לאחר סיום/שינוי העסקה
6.6	הסכמי סודיות/אי-גילוי (NDA)
6.7	עבודה מרחוק (Remote Working)
6.8	דיווח על אירועי אבטחת מידע (על ידי עובדים)

A.7 – בקורות פיזיות (14 בקורות)

עוסקות באבטחה פיזית וסביבתית:

#	בקרה
7.1	היקפי אבטחה פיזית
7.2	כניסה פיזית
7.3	אבטחת משרדים, חדרים ומתקנים
7.4	ניטור אבטחה פיזית – חדשה ב-2022
7.8-7.5	הגנה מפני איומים פיזיים/סביבתיים, עבודה באזורים מאובטחים, אבטחת ציוד
7.9	אבטחת נכסים מחוץ למתחם הארגון
7.10	מדיה אחסון (Storage Media)
7.11-7.14	תשתיות תומכות, כבילה, תחזוקת ציוד, סילוק/מיחזור בטוח

A.8 – בקורות טכנולוגיות (34 בקורות)

הקטגוריה הטכנית – התחום המוכר ביותר לאנשי IT ואבטחת מידע:

#	בקרה
8.1	מכשירי קצה של משתמשים
8.2	זכויות גישה מיוחסות (Privileged Access)
8.3	הגבלת גישה למידע
8.5	אימות מאובטח (Secure Authentication)
8.7	הגנה מפני קוד זדוני
8.8	ניהול חולשות טכניות (Vulnerability Management)
8.9	ניהול תצורה (Configuration Management) — חדשה ב-2022
8.10	מחיקת מידע — חדשה ב-2022
8.11	מיסוך נתונים (Data Masking) — חדשה ב-2022
8.12	מניעת דליפת מידע (DLP) — חדשה ב-2022
8.13	גיבוי מידע
8.14	יתירות של מתקני עיבוד מידע
-8.15 8.17	רישום אירועים (Logging), ניטור פעילויות, סנכרון שעונים
8.16	פעילויות ניטור (Monitoring Activities) — חדשה ב-2022
8.18	שימוש בתוכנות שירות (Utility Programs) פריבילגיות
-8.19 8.21	התקנת תוכנה, אבטחת רשתות, אבטחת שירותי רשת
-8.22 8.23	הפרדת רשתות, סינון אינטרנט (Web filtering) — חדשה ב-2022
8.24	שימוש בקריפטוגרפיה
-8.25 8.34	מחזור חיי פיתוח מאובטח (Secure SDLC): דרישות אבטחה, ארכיטקטורה מאובטחת, קידוד מאובטח, בדיקות אבטחה, פיתוח מיקור-חוץ, סביבות פיתוח/בדיקה/הפקה נפרדות, ניהול שינויים, בדיקות קבלה

מיפוי בקורות בין 2013 ל-2022

93 הבקורות של 2022 אינן "מהמצאה מחדש" — רובן מיזוג ושילוב של בקורות ממהדורת 2013, לצד **11 בקורות חדשות לגמרי** (המסומנות למעלה): מודיעין איומים, ICT readiness להמשכיות עסקית, ניטור אבטחה פיזית, ניהול תצורה, מחיקת מידע, מיסוך נתונים, DLP, פעילויות ניטור, אבטחת ענן ביחסי ספקים, וסינון אינטרנט. טבלת מיפוי רשמית (Correlation Matrix) מפורסמת על ידי ISO ומסייעת לארגונים מוסמכים לעדכן את ה-SoA שלהם בעת מעבר בין מהדורות (ראו פרק 7).

עקרון מנחה: הבקרה היא כלי, לא מטרה

חשוב לזכור בכל בקרה: השאלה הנכונה אינה "האם יישמנו את הבקרה?" אלא "**האם הבקרה מטפלת בסיכון שזיהינו, באפקטיביות מספקת, ובאופן שניתן להוכיח בביקורת (עדות, לוגים, נהלים, תיעוד)?**". בקרה שמיושמת "כי כתוב בתקן" בלי קשר לסיכון בפועל היא לרוב סימן לגישה בירוקרטית ולא לניהול סיכונים אמיתי.

פרק 4: תקנים נגזרים ממשפחת ISO/IEC 27000

פרק זה סוקר את התקנים העיקריים במשפחת ISO/IEC 27000 מעבר ל-27001 עצמו — כולם תקני הנחיה, למעט 27701 שניתן להסמכה כתוספת (extension) ל-27001.

4.1 התקנים "הליבתיים" התומכים ישירות

ISO/IEC 27000 — סקירה ואוצר מילים

תקן מבוא **חינמי** (ISO מפרסמת אותו ללא תשלום) המספק סקירה כללית של משפחת 27000 ומילון מונחים מאוחד. נקודת פתיחה טובה למי שרוצה להבין את מפת הדרכים לפני שרוכשים תקנים ספציפיים.

ISO/IEC 27002 — קוד התנהגות לבקורות אבטחת מידע

"התאום" הישיר של 27001: מפרט **כיצד** ליישם כל אחת מ-93 הבקורות בנספח A — לכל בקרה יש מטרה (Purpose), הנחיה מפורטת ליישום, ולעיתים מידע נוסף. זהו המסמך שבו נעזרים בפועל בעת כתיבת נהלים ובקורות בשטח, בעוד ש-27001 קובע רק אילו בקורות לשקול ומה צריך להיות קיים ברמה הניהולית.

ISO/IEC 27003 — הנחיות ליישום

מדריך מעשי, שלב-אחר-שלב, להקמת ISMS: מ-buy-in של ההנהלה, דרך הגדרת היקף, הערכת סיכונים, ועד הכנה לביקורת הסמכה. שימושי במיוחד לארגונים שמיישמים לראשונה.

ISO/IEC 27004 — ניטור, מדידה, ניתוח והערכה

מרחיב את דרישת סעיף 9.1 של 27001: איך בונים תכנית מדידה, בוחרים מדדים (KPIs) משמעותיים לאבטחת מידע (לא רק "מספר אירועים" אלא מדדים שמראים אפקטיביות בקורות בפועל), ואיך מדווחים עליהם להנהלה.

ISO/IEC 27005 — ניהול סיכונים אבטחת מידע

התקן המרכזי התומך בסעיף 6.1.2 ו-8.2 (הערכת וטיפול בסיכונים). מספק מסגרת מושגית לתהליך ניהול סיכונים (זיהוי, ניתוח, הערכה, טיפול, ניטור, תקשורת), **מבלי לכפות מתודולוגיה ספציפית** — ארגון יכול לבחור בין גישות איכותניות, כמותיות, או היברידיות (לדוגמה, מודל Likelihood × Impact כפי שממומש בכלי [cwe_risk_calculator.py](#) הנלווה לספר זה). המהדורה העדכנית (2022) מיושרת מלאה עם ISO 31000 (ניהול סיכונים ארגוני כללי).

ISO/IEC 27006 – דרישות לגופי ביקורת והסמכה

תקן טכני המיועד **לגופי ההסמכה עצמם** (לא לארגונים המוסמכים) – קובע את הדרישות שגוף הסמכה (כמו BSI, DNV, TÜV, SGS ואחרים) חייב לעמוד בהן כדי להיות מוכר כמוסמך להעניק תעודות ISO/IEC 27001.

ISO/IEC 27007 – הנחיות לביקורת ISMS

מדריך למבקרים (פנימיים וחיצוניים) על ניהול תכנית ביקורת, תכנון ביקורת בודדת, ואיסוף עדות ביקורת – משלים את ISO 19011 (הנחיות ביקורת מערכות ניהול כלליות) עם היבטים ייחודיים ל-ISMS.

ISO/IEC TS 27008 – הנחיות למבקרי בקורות אבטחת מידע

ממוקד יותר מ-27007: איך בודקים **בפועל** שבקרה טכנית מיושמת כראוי (בדיקות טכניות, סקירת תצורה) – משלים בין ביקורת ניהולית (27007) לבדיקה טכנית.

4.2 תקני מגזר (Sector-specific)

ISO/IEC 27009 – יישום ספציפי למגזר

"מטא-תקן" שקובע **איך** מפתחים תקן ISMS ספציפי-מגזר (sector-specific) שמבוסס על 27001/27002 – למשל איך 27019 או 27799 (ראו למטה) הורשו להוסיף בקורות ייחודיות מבלי לסתור את הדרישות הבסיסיות.

ISO/IEC 27011 – טלקומוניקציה

התאמת בקורות 27002 לארגוני תקשורת (ITU-T X.1051), עם דגש על אבטחת תשתיות רשת קריטיות ושיתוף מידע בין מפעילים.

ISO/IEC 27019 – תעשיית האנרגיה

בקורות ייעודיות למערכות בקרה תעשייתיות (ICS/SCADA) בענף האנרגיה (חשמל, גז, נפט) – כולל היבטים ייחודיים כמו זמינות קריטית ומערכות legacy.

ISO/IEC 27799 – מידע בריאותי (Health Informatics)

מדריך ליישום 27002 בארגוני בריאות, מותאם לרגישות מידע רפואי ולדרישות כמו HIPAA (בארה"ב) ותקנות בריאות מקומיות.

4.3 תקני ענן ופרטיות

ISO/IEC 27017 – בקורות אבטחת מידע לשירותי ענן

מוסיף הנחיות ובקורות ספציפיות לענן על גבי 27002: **הבהרת אחריות** בין ספק הענן (Cloud Service Provider) ללקוח (Cloud Service Customer) לכל בקרה (מודל האחריות המשותפת – Shared Responsibility), ומוסיף 7 בקורות ייעודיות לענן (הפרדת סביבות וירטואליות, ניהול תצורת מכונות וירטואליות, פעולות ניהול ענן, ועוד).

ISO/IEC 27018 – הגנת מידע אישי (PII) בענן ציבורי

ממוקד בהגנת **מידע מזהה אישי (PII)** שמעובד על ידי ספקי ענן ציבורי בתפקיד מעבד (Processor) עבור לקוחותיהם. רלוונטי מאוד לתאימות ל-GDPR ולחוקי פרטיות דומים בעת רכישת שירותי ענן.

ISO/IEC 27701 – מערכת ניהול מידע פרטיות (PIMS)

התוספת (extension) המשמעותית ביותר ל-27001 – מרחיבה את ה-ISMS למערכת ניהול פרטיות מלאה (PIMS – Privacy Information Management System), עם דרישות נפרדות לארגונים בתפקיד **בקר מידע (Controller)** ולארגונים בתפקיד **מעבד מידע (Processor)**. ארגון שכבר מוסמך ל-27001 יכול "להרחיב" את ההסמכה שלו ל-27701 מבלי לבנות ISMS נפרד – משמש כלי מרכזי להפגנת תאימות ל-GDPR ולחוקי פרטיות אחרים (כולל חוק הגנת הפרטיות הישראלי המתוקן).

4.4 תקני נושא (Topic-specific)

תקן	נושא
ISO/IEC 27014	ממשל אבטחת מידע (Governance) – האחריות של הדירקטוריון וההנהלה הבכירה
ISO/IEC 27016	כלכלה ארגונית של אבטחת מידע – ניתוח עלות-תועלת של השקעות אבטחה
ISO/IEC 27021	דרישות כשירות למקצועני ISMS – "מפת" תפקידים וכישורים נדרשים
ISO/IEC 27032	הנחיות לאבטחת סייבר – משיק לאבטחת מידע אך מרחיב לזירת הסייבר (מרחב דיגיטלי משותף, תיאום בין ארגונים)
ISO/IEC 27033 (סדרה, חלקים 1-6)	אבטחת רשתות – עיצוב, יישום, תרחישי רשת (VPN, אלחוט וכו')
ISO/IEC 27034 (סדרה)	אבטחת יישומים (Application Security) – מסגרת ל-SDLC מאובטח ברמת ארגון ופרויקט
ISO/IEC 27035 (חלקים 1-3)	ניהול אירועי אבטחת מידע – מרחיב את A.5.24-5.28: תכנון, גילוי, הערכה, תגובה, למידה
	אבטחת מידע ביחסי ספקים – כולל שרשרת אספקה ושירותי ענן

תקן	נושא
ISO/IEC 27036 (חלקים 1-4)	
-ISO/IEC 27037 27050, 27043	משפחת פורנזיקה דיגיטלית וגילוי אלקטרוני: זיהוי/איסוף/שימור ראיות דיגיטליות (27037), חקירת אירועים (27042), נאותות חקירה (27043), eDiscovery (27050)

4.5 תקנים קרובים מחוץ למשפחת 27000

- **ISO 22301 — ניהול המשכיות עסקית (BCM):** תקן עצמאי (לא חלק פורמלי ממשפחת 27000, אך משיק ישירות ל-5.30-5.29 A). ארגונים רבים משלבים 27001 ו-22301 יחד.
- **ISO 31000 — ניהול סיכונים, עקרונות והנחיות:** המסגרת הארגונית הכללית לניהול סיכונים שעליה מבוסס ISO/IEC 27005.
- **ISO/IEC 20000-1 — ניהול שירותי IT:** תקן ITSM (מבוסס ITIL); ISO/IEC 27013 מסביר איך ליישם 27001 ו-20000-1 יחד ביעילות.
- **ISO 9001 — ניהול איכות:** התקן ה"אב" שממנו נגזר מבנה Annex SL המשותף.

4.6 טבלת סיכום מהירה

תקן	סוג	שימוש עיקרי
27001	דרישות (ניתן להסמכה)	ה-ISMS עצמו
27002	הנחיה	איך ליישם בקורות נספח A
27005	הנחיה	מתודולוגיית ניהול סיכונים
27017	הנחיה	בקורות ענן + אחריות משותפת
27018	הנחיה	הגנת PII בענן ציבורי
27701	דרישות (הרחבת הסמכה)	PIMS — ניהול פרטיות
27032	הנחיה	אבטחת סייבר
27035	הנחיה	ניהול אירועי אבטחת מידע
27036	הנחיה	אבטחת שרשרת ספקים
22301	דרישות (ניתן להסמכה, תקן נפרד)	המשכיות עסקית

פרק 5: תהליך ההסמכה והביקורת

5.1 מי מסמך את מי

ISO (הארגון הבינלאומי לתקינה) אינו מעניק תעודות הסמכה בעצמו. ההסמכה מתבצעת על ידי **גופי הסמכה (Certification Bodies)** עצמאיים — לדוגמה BSI, DNV, TÜV SÜD/Rheinland, SGS, Bureau Veritas ואחרים — שעצמם מוסמכים ("מוכרים") על ידי **גוף הכרה לאומי (Accreditation Body)** במדינתם (למשל UKAS בבריטניה, ANAB בארה"ב, או הרשות להסמכת מכונים בישראל). גוף ההסמכה פועל לפי דרישות **ISO/IEC 27006** (פרק 4).

בבחירת גוף הסמכה כדאי לוודא: - שהוא **מוכר (Accredited)** על ידי גוף הכרה מוכר בינלאומית (חבר ב-IAF — International Accreditation Forum), כדי שהתעודה תוכר בעולם. - שיש לו ניסיון בתחום/במגזר הארגון. - עלות ותנאי חוזה סבירים (הסמכה כרוכה במחויבות רב-שנתית, ראו למטה).

5.2 שלבי התהליך המלא

שלב 0: הכנה (לפני מעורבות גוף ההסמכה)

כולל את כל תהליך היישום המפורט בפרק 6 — הגדרת היקף, הערכת סיכונים, SoA, יישום בקורות, ביקורת פנימית, סקר הנהלה. **גוף ההסמכה לא מלווה את ההטמעה** — תפקידו לבדוק ולאשר (או להעריך יועץ חיצוני / מומחה פנימי מלווה את ההטמעה עצמה, בנפרד מגוף ההסמכה, כדי לשמור על עצמאות המבקר).

שלב 1: Stage 1 Audit (ביקורת שולחן / Documentation Review)

ביקורת ראשונית, בדרך כלל מרחוק או קצרה באתר, שבדקת: - שהתיעוד (מדיניות, נהלים, SoA, הערכת סיכונים) קיים ותואם בסיס לדרישות התקן. - מוכנות הארגון לביקורת Stage 2 (האם ה-ISMS "בשל" מספיק). - זיהוי פערים מהותיים מוקדם, לפני שמשקיעים בביקורת מלאה. בסיום Stage 1 מתקבל דו"ח עם ממצאים (אם יש) שיש לטפל בהם לפני Stage 2.

שלב 2: Stage 2 Audit (ביקורת יישום)

ביקורת מעמיקה באתר (או משולבת מרחוק, בהתאם למדיניות גוף ההסמכה), שבדקת: - **יישום בפועל** של הבקורות שנבחרו ב-SoA — לא רק תיעוד, אלא עדות אמיתית (לוגים, ראיונות עם עובדים, תצפית על תהליכים). - אפקטיביות ה-ISMS: האם התהליכים (ביקורת פנימית, סקר הנהלה, טיפול באי-התאמות) פעלו בפועל ולא רק "על הנייר". - ראיונות עם בעלי תפקידים מרכזיים (CISO, בעלי נכסים, IT, HR, לעיתים הנהלה בכירה).

בסיום, המבקר מסכם ממצאים שמסווגים ל: - **אי-התאמה חמורה (Major Nonconformity)** — כשל מהותי שמונע הסמכה עד לתיקון ואימות. - **אי-התאמה קלה (Minor Nonconformity)** —

פער נקודתי; לרוב לא חוסם הסמכה אך דורש תכנית תיקון ומעקב בביקורת הבאה. - **הזדמנות לשיפור (Observation)** — לא אי-התאמה, אך המלצה.

שלב 3: קבלת התעודה

לאחר סגירת אי-התאמות חמורות (וברוב המקרים גם קלות בתוך פרק זמן שנקבע), גוף ההסמכה מנפיק תעודה בתוקף ל-3 שנים.

שלב 4: ביקורות מעקב (Surveillance Audits)

בכל אחת מהשנתיים שלאחר ההסמכה (בד"כ שנה 1 ושנה 2) מתבצעת ביקורת מעקב חלקית — לא כל ה-ISMS נבדק מחדש, אלא מדגם של תחומים, כדי לוודא שהמערכת עדיין פעילה ומתוחזקת.

שלב 5: ביקורת חידוש (Recertification Audit)

בסוף השנה השלישית, ביקורת מלאה (בהיקף דומה ל-Stage 2) לחידוש התעודה לתקופה נוספת של 3 שנים.

5.3 ביקורת פנימית מול ביקורת הסמכה (חיצונית)

ביקורת פנימית (9.2)	ביקורת הסמכה (חיצונית)	
עובד/יועץ פנימי אובייקטיבי (לא מבקר את תחומו)	מבקר מוסמך מטעם גוף הסמכה מוכר	מי מבצע
לפי תכנית שקובע הארגון (בד"כ שנתית)	Stage 1/2 בהסמכה ראשונית, מעקב שנתי, חידוש כל 3 שנים	תדירות
לספק להנהלה עדות עצמאית שה-ISMS תקין, לפני שהחיצוני מגיע	להעניק/לשמר תעודה רשמית מוכרת	מטרה
ממצאים פנימיים, קלט לסקר הנהלה	תעודת הסמכה / דו"ח אי-התאמות רשמי	תוצר

ביקורת פנימית טובה היא **קו ההגנה הראשון** לפני ביקורת חיצונית — ארגון שמזלזל בביקורת הפנימית ("רק כדי לסמן וי") לרוב מגלה זאת ביוקר בביקורת ההסמכה.

5.4 טעויות נפוצות בתהליך ההסמכה

- **הרצה לקראת הביקורת** — בניית תיעוד "יפה" רק סמוך למועד הביקורת, בלי שהתהליכים פעלו זמן מספיק כדי לצבור עדות אמיתית (ביקורת פנימית אחת, סקר הנהלה אחד — לא מספיקים "רגע לפני").
- **היקף (Scope) לא ריאלי** — היקף רחב מדי (כל הארגון, כל המערכות) כשאין משאבים לתחזק זאת, או היקף צר מדי שלא משקף את הסיכון האמיתי ומעורר שאלות אצל לקוחות/רגולטורים.
- **SoA שהוא "העתק-הדבק" מתבנית** — ללא קשר אמיתי להערכת הסיכונים של הארגון הספציפי.

- **חוסר מעורבות הנהלה בכירה** – סעיף 5.1 דורש מחויבות פעילה, לא רק חתימה על מדיניות.
- **בחירת גוף הסמכה לא מוכר (unaccredited)** – תעודה שלא תוכר על ידי לקוחות/שותפים בינלאומיים.

פרק 6: יישום מעשי בארגון

פרק זה מציג מפת דרכים מעשית להטמעת ISMS לפי ISO/IEC 27001, מהחלטה ראשונית ועד ביקורת הסמכה, עם דגש על הכלים הפרקטיים שהופכים את התקן ממסמך תיאורטי לתהליך עבודה.

6.1 מפת דרכים להטמעה (סדר מומלץ)

1. **גיוס תמיכת הנהלה בכירה (Sponsorship)** — ללא זה, סעיף 5.1 ייכשל מלכתחילה. יש להציג עלות מול תועלת (עסקית: דרישת לקוחות/מכרזים, הפחתת סיכון, יתרון תחרותי; לא רק "כירצון").
2. **הגדרת היקף (Scope)** — בחירת מוצרים/שירותים/יחידות/מיקומים שייכללו. כלל אצבע: התחילו בהיקף ממוקד (למשל מוצר SaaS אחד, לא כל החברה), הרחיבו בהמשך.
3. **מינוי אחראי (ISMS (CISO/Information Security Manager)** ותפקידים נלווים: בעלי נכסים, בעלי סיכונים.
4. **מיפוי נכסי מידע** — מערכות, מאגרי מידע, תשתיות, ספקים קריטיים — הבסיס להערכת הסיכונים.
5. **הערכת סיכונים (Risk Assessment)** — לפי מתודולוגיה עקבית (ISO/IEC 27005, פרק 4). כאן נכנס לשימוש כלי כמו `cwe_risk_calculator.py` הנלווה לספר, כדוגמה למודל ניקוד $Likelihood \times Impact$ עבור חולשות טכניות מזוהות (למשל מתוצאות סקירת קוד, בדיקות חדירה, או סריקות פגיעויות שממופות ל-CWE) — ראו 6.3 למטה.
6. **טיפול בסיכונים ובניית ה-SoA** — בחירת בקורות מנספח A (או מקורות נוספים), תיעוד הנמקה לכל בקרה שנכללה/הוחרגה.
7. **יישום הבקורות** — הפרויקט "הכבד" בפועל: מדיניות, נהלים, שינוי תהליך, הטמעת בקורות טכניות.
8. **הכשרה ומודעות (7.2-7.3)** — לכל העובדים הרלוונטיים, לא רק ל-IT.
9. **הפעלה שוטפת ואיסוף עדות** — לתת ל-ISMS "לרוץ" מספיק זמן (מומלץ לפחות 2-3 חודשים) כדי לצבור לוגים, רישומי אירועים, בקשות גישה וכו', לפני ביקורת פנימית.
10. **ביקורת פנימית (9.2)** — בדיקה עצמאית שהכול פועל כמתוכנן.
11. **סקר הנהלה (9.3)** — ההנהלה סוקרת תוצאות, מקבלת החלטות.
12. **טיפול באי-התאמות שעלו (10.2)** לפני הביקורת החיצונית.
13. **ביקורת הסמכה (פרק 5)**.

6.2 מבנה תיעוד מומלץ

רמה	מסמכים לדוגמה
1. מדיניות (Policy)	מדיניות אבטחת מידע ראשית, מדיניות פרטיות
2. נהלים (Procedures)	ניהול סיכונים, ניהול אירועים, ניהול גישה, ניהול שינויים, המשכיות עסקית
	הקשחת שרתים, נוהל גיבוי טכני, checklist onboarding/offboarding

רמה	מסמכים לדוגמה
3. הנחיות עבודה (Work Instructions)	
4. רשומות (Records)	דוחות ביקורת פנימית, פרוטוקולי סקר הנהלה, רשומת סיכונים, יומני אירועים

מסמך-העל המקשר בין הכול הוא ה-**SoA**: לכל בקרה — האם נכללה, מקור ההחלטה (תוצאת הערכת סיכונים / דרישה חוזית / דרישה רגולטורית), וקישור לנוהל/בקרה המיישמים אותה.

6.3 שימוש בכלי מחשבון הסיכונים המבוסס-CWE

בעת הערכת סיכונים לרכיבי תוכנה (יישומי Web, שירותי API, קוד פנימי), נפוץ שמקור הממצאים הוא כלי סריקה סטטית/דינמית, מבדק חדירה, או ביקורת קוד — וממצאים אלו לרוב ממופים למזהי **CWE** (Common Weakness Enumeration) סטנדרטיים. הכלי הנלווה `iso27001-book/tools/cwe_risk_calculator.py` ממחיש כיצד להפוך רשימת ממצאי CWE גולמית לרשומת סיכונים מדורגת, בהתאם למתודולוגיית ISO/IEC 27005 שתוארה בפרק 4:

```
# ים נתמכים בכלי, כולל ערכי ברירת מחדל-CWE הצגת רשימת
python3 iso27001-book/tools/cwe_risk_calculator.py list

# חישוב רשומת סיכונים מלאה מקובץ ממצאים, ממוינת מהחמור לקל
python3 iso27001-book/tools/cwe_risk_calculator.py report \
--input iso27001-book/tools/sample_findings.json \
--output risk_register.csv
```

התוצאה (רשומת סיכונים ממוינת עם רמת סיכון Low/Medium/High/Critical) יכולה לשמש כקלט ישיר לתכנית טיפול בסיכונים (6.1.3) — למשל: סיכונים ברמת Critical מטופלים לפני ההסמכה, סיכוני Medium מקבלים תכנית טיפול עם יעד זמן, וסיכוני Low מתועדים כקבלת סיכון (Risk Acceptance) עם אישור בעל הסיכון. **חשוב לשוב ולהדגיש** (כמפורט ב- `tools/README.md`): ערכי ברירת המחדל בכלי הם דוגמה פדגוגית ולא הערכה מדויקת של סיכון בפועל — יש לכייל likelihood/impact לפי ההקשר האמיתי (חשיפה לאינטרנט, רגישות הנתונים, בקורות מפצות קיימות).

6.4 מדדים (KPIs) לדוגמה

- זמן ממוצע לזיהוי אירוע אבטחה (MTTD) וזמן ממוצע לתגובה (MTTR).
- אחוז עובדים שהשלימו הדרכת מודעות שנתית.
- אחוז חולשות קריטיות/גבוהות שנסגרו בתוך SLA שהוגדר (למשל 30/90 יום).
- מספר אי-התאמות פתוחות מביקורת פנימית/חיצונית, לפי חומרה.
- אחוז נכסים עם בעלים (Asset Owner) מוגדר במלאי הנכסים.

6.5 תרבות אבטחת מידע – לא רק תיעוד

התקן דורש תיעוד, אך תיעוד לבדו לא מייצר אבטחה. ISMS אפקטיבי דורש: - **מעורבות הנהלה** **אמיתית**, לא רק חתימה פורמלית. - **תקשורת שוטפת** (לא רק הדרכה שנתית חד-פעמית) – עדכוני איומים, תרגולי פשינג, שיתוף לקחים מאירועים. - **תהליך דיווח אירועים ידיוותי** – עובדים שמפחדים לדווח על טעות (למשל לחצו על קישור חשוד) מעכבים גילוי מוקדם. - **שילוב אבטחה ב-SDLC** ולא כשכבה שמתווספת בסוף (Shift Left).

6.6 שילוב עם מערכות ניהול אחרות

ארגון שכבר מיישם ISO 9001 (איכות) או ISO 22301 (המשכיות עסקית) יכול לבנות **Integrated Management System (IMS)** בזכות מבנה Annex SL המשותף – סעיפי 4-10 כמעט זהים במבנה, מה שמפחית כפילות בתיעוד (למשל: מדיניות אחת מאוזכרת, תהליך ביקורת פנימית אחד שמכסה כמה תקנים, סקר הנהלה משולב).

פרק 7: 2013 מול 2022 – מה השתנה

7.1 שינויים בגוף התקן (סעיפים 4-10)

השינויים בדרישות עצמן (בניגוד לנספח A) מתונים יחסית – בעיקר ניסוח מחדד וסעיף חדש אחד:

- **סעיף 4.2** – הרחבה לכלול "אילו מהדרישות [של בעלי עניין] ייענו דרך ה-ISMS" (הבהרה שלא כל דרישת בעל עניין חייבת להיכנס להיקף ה-ISMS).
- **סעיף 4.4** – תוספת ניסוחית: "כולל את התהליכים הנדרשים ואת האינטראקציות ביניהם", דגש מוגבר על ראייה תהליכית.
- **סעיף 6.1.3** – הבהרת ניסוח בנוגע להשוואת בקורות שנבחרו מול נספח A.
- **סעיף 6.2** – הוספת דרישה שיעדי אבטחת מידע יהיו **ניתנים לניטור** (monitored) – לא רק מתועדים.
- **סעיף 6.3** – "תכנון שינויים" (**Planning of changes**) – **סעיף חדש לגמרי**. דורש שכאשר ה-ISMS זקוק לשינוי (למשל שינוי היקף, אימוץ טכנולוגיה חדשה, שינוי ארגוני), השינוי יתבצע בצורה מתוכננת ומבוקרת, ולא אד-הוק.
- **סעיף 7.4** – פישוט קל בניסוח דרישות התקשורת.
- **סעיף 9.1, 9.2, 9.3** – מבנה מחודד יותר (חלוקה ל-9.2.1/9.2.2 ו-9.3.1/9.3.2/9.3.3), בעיקר להבהרה ולא לתוספת דרישה מהותית.
- **סעיף 10** – **הוחלף הסדר**: ב-2013 "אי-התאמה ופעולה מתקנת" (10.1) קדם ל"שיפור מתמשך" (10.2). ב-2022 הסדר ההפך (10.1 שיפור מתמשך, 10.2 אי-התאמה), וניסוח שיפור מתמשך התקצר משמעותית.

המסקנה המעשית: ארגון שכבר מוסמך ל-2013 לא צריך לבנות ISMS מחדש – עיקר העבודה במעבר היא **עדכון ה-SoA וההערכה מחדש של הבקורות** (ראו 7.2), ותוספת תהליך פורמלי לניהול שינויים ב-(6.3) ISMS.

7.2 השינוי המרכזי: ריענון נספח A

	2013	2022
מספר בקורות	114	93
מספר קטגוריות	14 (A.5-A.18)	4 (ארגוניות, אנשים, פיזיות, טכנולוגיות)
בקורות חדשות	—	11 בקורות חדשות (ראו פרק 3)
בקורות שמוזגו	—	כ-57 בקורות מ-2013 מוזגו לתוך פחות בקורות ב-2022
בקורות ששונה שמן בלבד	—	23 בקורות
בקורות ללא שינוי	—	35 בקורות
תכונות (Attributes)	לא היו	נוספו 5 סוגי תכונות לכל בקרה (סעיף פרק 3)

הירידה ממספר גדול של קטגוריות צרות (14) לארבע קטגוריות רחבות משקפת מגמה כללית ב-ISO להפוך את הנספח לניתן-לניווט יותר, ולהדגיש קשרים חוצי-נושא (objectives) דרך התכונות ולא רק דרך מיקום הבקרה במסמך.

7.3 מה זה אומר לארגון מוסמך קיים

ISO קבעה **תקופת מעבר** (transition period) – ארגונים מוסמכים ל-ISO/IEC 27001:2013 נדרשו לעבור ל-2022 עד למועד יעד שקבע ה-IAF (בפועל, רוב גופי ההסמכה דרשו מעבר עד סוף 2025, במסגרת ביקורת מעקב או חידוש רגילה – ולא דרשו ביקורת מיוחדת נפרדת). מי שעדיין מחזיק בהסמכת 2013 בתוקף אחרי מועד היעד – ההסמכה כבר אינה תקפה להכרה בינלאומית.

שלבי המעבר המומלצים לארגון מוסמך: 1. מיפוי (Correlation Matrix) בין 114 הבקורות הישנות ל-93 החדשות (מפורסם על ידי ISO ועל ידי גופי ההסמכה). 2. עדכון ה-SoA לפי המבנה החדש (4 קטגוריות, כולל תכונות אם רוצים לנצל אותן לניתוח). 3. **הערכת סיכונים ממוקדת** ל-11 הבקורות החדשות (במיוחד: מודיעין איומים, ICT readiness להמשכיות עסקית, ניהול תצורה, מחיקת מידע, מיסוך נתונים, DLP, אבטחת ענן ביחסי ספקים) – האם ואיך הן רלוונטיות לארגון. 4. עדכון מדיניות ונהלים בהתאם לבקורות החדשות שנבחרו. 5. שילוב הביקורת בתהליך ביקורת המעקב או החידוש הקרובה (אין צורך בביקורת מיוחדת נפרדת, בכפוף למדיניות גוף ההסמכה הספציפי).

7.4 עדכון מקביל: ISO/IEC 27002

ISO/IEC 27002:2022 פורסם **לפני** 27001:2022 (בפברואר 2022, מול אוקטובר 2022), משום שהוא הבסיס שממנו "יוצא" נספח A. כל ארגון שמעדכן SoA צריך להיעזר ב-27002:2022 (לא 2013) לצורך ההנחיה המפורטת ליישום כל בקרה.

פרק 8: מילון מונחים ורשימת בדיקה

8.1 מילון מונחים

מונח	הסבר
ISMS	Information Security Management System – מערכת ניהול אבטחת מידע
Asset (נכס)	כל דבר בעל ערך לארגון: מידע, מערכת, שירות, אנשים, מוניטין
Asset Owner (בעל נכס)	האחראי הארגוני על נכס מסוים, כולל אחריות להערכת הסיכון שלו
Threat (איום)	גורם פוטנציאלי לאירוע לא רצוי שעלול לפגוע בארגון
Vulnerability (חולשה)	חולשה בנכס שאיום יכול לנצל (לעיתים ממופה ל-CWE ברמה הטכנית)
Risk (סיכון)	השפעה של אי-ודאות על יעדים; לרוב מחושב כפונקציה של סבירות X השפעה
Likelihood (סבירות)	ההסתברות שאיום ינצל חולשה בפועל
Impact (השפעה)	היקף הנזק הפוטנציאלי אם הסיכון יתממש
Risk Treatment (טיפול בסיכון)	הפחתה (Mitigate), העברה (Transfer), הימנעות (Avoid), קבלה (Accept)
Risk Owner (בעל סיכון)	האחראי לקבל החלטה על אופן הטיפול בסיכון מסוים ולאשר קבלתו
SoA – Statement of Applicability	הצהרת ההתאמה: מסמך המפרט אילו בקורות נבחרו/הוחרגו ומדוע
Residual Risk (סיכון שייר)	הסיכון שנותר לאחר יישום בקורות טיפול
Control (בקרה)	אמצעי (טכני, ניהולי, פיזי) לשינוי סיכון
Nonconformity (אי-התאמה)	אי-עמידה בדרישה של התקן או של הארגון עצמו
Corrective Action (פעולה מתקנת)	פעולה לסילוק סיבת אי-התאמה כדי למנוע הישנות
Management Review (סקר הנהלה)	סקירה תקופתית של ה-ISMS על ידי ההנהלה הבכירה
Internal Audit (ביקורת פנימית)	ביקורת עצמאית בתוך הארגון לבדיקת תאימות ואפקטיביות
Certification Body (גוף הסמכה)	גוף חיצוני מוכר שמעניק תעודת הסמכה לתקן
Accreditation Body (גוף הכרה)	גוף לאומי שמכיר בגופי הסמכה
Stage 1 / Stage 2 Audit	שני שלבי ביקורת ההסמכה הראשונית (תיעוד, ואז יישום)
Surveillance Audit (ביקורת מעקב)	ביקורת חלקית שנתית בין ביקורות הסמכה/חידוש
PIMS	

מונה	הסבר
	ISMS — Privacy Information Management System לפי ISO/IEC 27701
PII	Personally Identifiable Information — מידע מזהה אישית
CIA Triad	Confidentiality, Integrity, Availability — משולש אבטחת המידע
CWE	Common Weakness Enumeration — קטלוג סטנדרטי של סוגי חולשות תוכנה
Annex SL	המבנה האחיד המשותף לכל תקני מערכות הניהול של ISO
PDCA	Plan-Do-Check-Act — מודל השיפור המתמשך של דמינג
Pentest (בדיקת חדירה)	ניסיון ידני מורשה לנצל חולשות בפועל, בשונה מסריקה אוטומטית (ראו פרק 9)
ROE — Rules of Engagement	מסמך המגדיר בכתב מה מותר/אסור לבדוק, טווח, חלון זמן, ואיש קשר לעצירת חירום
Black / Grey / White Box	רמת המידע המוקדם שמקבל בודק החדירה על המערכת הנבדקת
Red Team	סימולצית תוקף ריאליסטית וארוכת-טווח, לרוב ללא ידיעת צוות ההגנה (SOC)
/ PTES / OWASP Testing Guide OSSTMM	מתודולוגיות מוכרות לביצוע בדיקות חדירה (ראו פרק 9.3)
Retest (בדיקה חוזרת)	אימות לאחר תיקון שממצא pentest אכן נסגר בפועל

8.2 רשימת בדיקה (Checklist) ליישום והסמכה

שלב הכנה

- [] קיבלנו מחויבות מפורשת ומתועדת מההנהלה הבכירה
- [] מונה אחראי (CISO / Information Security Manager) ISMS
- [] הוגדר היקף ה-ISMS בכתב (מוצרים, שירותים, מיקומים, נכסים)
- [] זוהו כל בעלי העניין הרלוונטיים ודרשוניהם (חוזיות, רגולטוריות)

מדיניות ותכנון

- [] נכתבה ואושרה מדיניות אבטחת מידע
- [] הוגדרו תפקידים ואחריות (כולל בעלי נכסים ובעלי סיכונים)
- [] נבנה מלאי נכסי מידע מלא ומעודכן
- [] הוגדרה ותועדה מתודולוגיית הערכת סיכונים
- [] בוצעה הערכת סיכונים ראשונית מלאה

- [] נבנתה תכנית טיפול בסיכונים
- [] הופקה ואושרה הצהרת ההתאמה (SoA)
- [] הוגדרו יעדי אבטחת מידע מדידים

תמיכה ותפעול

- [] הוקצו משאבים מספקים (תקציב, כוח אדם, כלים)
- [] בוצעה הערכת מיומנות ותוכניות הכשרה לתפקידי מפתח
- [] בוצעה הדרכת מודעות לכלל העובדים
- [] הוגדר תהליך תקשורת פנימי/חיצוני בנושאי אבטחת מידע
- [] מבנה מסמכים מתועד (מדיניות → נהלים → הנחיות → רשומות) בשליטה
- [] הבקורות שנבחרו ב-SoA יושמו בפועל (טכנית וניהולית)
- [] קיים תהליך מוגדר לדיווח וטיפול באירועי אבטחת מידע

הערכה ושיפור

- [] הוגדרו מדדים (KPIs) ותהליך איסוף ודיווח שוטף
- [] בוצעה ביקורת פנימית מלאה, בלתי-תלויה, עם דו"ח ממצאים
- [] בוצע סקר הנהלה עם כל הקלטים הנדרשים (9.3)
- [] טופלו אי-התאמות שעלו, כולל ניתוח סיבה שורשית
- [] נאסף לפחות 2-3 חודשי עדות תפעולית לפני ביקורת הסמכה

הסמכה

- [] נבחר גוף הסמכה מוכר (Accredited, חבר IAF)
- [] עבר בהצלחה Stage 1 Audit וטופלו הממצאים
- [] עבר בהצלחה Stage 2 Audit וטופלו הממצאים
- [] התקבלה תעודת הסמכה
- [] נקבעה תכנית ביקורות מעקב שנתיות ותהליך שימור מתמשך

אחזוקה שוטפת (Continuous)

- [] מחזור PDCA פעיל: הערכת סיכונים מתעדכנת, SoA מתעדכן בעת שינויים
- [] תכנית ביקורות פנימיות שנתיות מתקיימת בפועל
- [] סקרי הנהלה מתקיימים לפי התכנון
- [] מעקב שוטף אחר עדכוני התקן (כמו המעבר 2013→2022, ראו פרק 7)

זהו סיכום הספר. לחזרה לתחילת הספר ולתוכן העניינים המלא — ראו [README.md](#).

פרק 9: בדיקות חדירה (Pentesting) ו-ISO/IEC 27001

9.1 מה בדיוק דורש התקן – ומה הוא לא דורש

זו נקודה שמבלבלת ארגונים רבים: **ISO/IEC 27001 לא מכיל את המילה "penetration test" כדרישה מפורשת**. אין סעיף שאומר "יש לבצע בדיקת חדירה פעם בשנה". במקום זאת, התקן דורש **תוצאות** – ניהול חולשות טכניות אפקטיבי, ראייה שבקורות עובדות, והערכת סיכונים מבוססת-ראיות – ומשאיר לארגון לבחור **באיזה אמצעי** הוא מגיע לתוצאות האלה. בפועל, בדיקת חדירה היא **אחת הטכניקות המרכזיות והנפוצות ביותר** להשגת התוצאות שהבקורות הבאות דורשות:

בקרת נספח A	איך pentest משרת אותה
A.8.8 – ניהול חולשות טכניות	pentest הוא מקור מרכזי לזיהוי חולשות בסביבת ההפעלה בפועל, לא רק סריקה אוטומטית
A.8.29 – בדיקות אבטחה בפיתוח ובקבלה	pentest ליישומים/גרסאות לפני עלייה לפרודקשן
A.5.36 – סקירת עמידה במדיניות ובתקנים טכניים	pentest מספק עדות אובייקטיבית לפער בין מדיניות למציאות
A.5.7 – מודיעין איומים	ממצאי pentest (וטכניקות תוקפים אמיתיות) מזינים את הבנת האיום הרלוונטי לארגון
A.8.16 – פעילויות ניטור	pentest בודק אם הניטור בפועל מזהה פעילות תוקף (לעיתים כ-Purple/Red Team)
8.2 / 6.1.2 – הערכת סיכונים	ממצאי pentest הם קלט קונקרטי, לא תיאורטי, להערכת סיכונים
10.2 – אי-התאמה ופעולה מתקנת	ממצא pentest חמור שלא נסגר = לרוב אי-התאמה של ממש בביקורת

המשמעות המעשית: מבקר הסמכה (Certification Auditor) לא ישאל "תראו לי את דוח בדיקת החדירה" כדרישה פורמלית – אבל כן ישאל "איך אתם יודעים שבקורות ה-A.8.8/A.8.29 שלכם אפקטיביות?", ותשובה משכנעת כמעט תמיד כוללת pentest תקופתי עם ראייה לטיפול בממצאים.

9.2 סוגי בדיקות – טרמינולוגיה חיונית

בלבול נפוץ הוא זיהוי מוטעה בין כלים/שירותים שנשמעים דומה אך שונים מהותית באופיים, בעלות, ובערך שהם מספקים:

סוג	מה זה	עומק	תדירות טיפוסית
סריקת חולשות (Vulnerability Scan)	כלי אוטומטי (Nessus, Qualys, OpenVAS) מזהה חולשות ידועות	רדוד, ללא ניצול בפועל	שוטף (שבועי/חודשי)
בדיקת חדירה (Penetration Test)	בודק אנושי מנסה לנצל בפועל חולשות, מדמה תוקף עם יעד מוגדר	עמוק, ידני+כלים	שנתי / אחרי שינוי מהותי
Red Team	סימולציה ארוכת-טווח ומחמיקה של תוקף מתוחכם, לרוב ללא ידיעת צוות ה-SOC (מבחן Purple אם בשיתוף)	עמוק מאוד, ריאליסטי, ממוקד-מטרה לא ממוקד-כיסוי	מתקדם, לא לכל ארגון
Bug Bounty	תגמול לחוקרים חיצוניים תמורת דיווח חולשות, כיסוי מתמשך	משתנה מאוד	מתמשך
סקירת קוד/ארכיטקטורה (Code/Architecture Review)	בדיקה סטטית של קוד/עיצוב, לא של המערכת הרצה	עמוק בשכבת הקוד	שלב פיתוח, לפי SDLC

בתוך "בדיקת חדירה" עצמה יש עוד ציר סיווג:

- **Black box** — הבודק מקבל רק מטרה (למשל דומיין), ללא מידע פנימי — מדמה תוקף חיצוני חסר-ידע מוקדם.
 - **Grey box** — הבודק מקבל מידע חלקי (למשל חשבון משתמש רגיל) — מדמה תוקף עם דריסת רגל התחלתית (עובד זדוני, לקוח, שותף).
 - **White box** — הבודק מקבל גישה מלאה (קוד מקור, ארכיטקטורה, אישורים) — הכי יעיל למציאת חולשות עומק, פחות מדמה תוקף אמיתי.
- וכן לפי **וקטור**: יישומי (OWASP Web, רשת/תשתית (חיצונית/פנימית), אלחוט, הנדסה חברתית (פשיג, Vishing), פיזי (ניסיון כניסה פיזית), ענן (AWS/Azure/GCP misconfig), ומובייל.

9.3 מתודולוגיות מוכרות בעולם

בעת הזמנת/ביצוע pentest, שווה להסכים מראש על מתודולוגיה מוכרת — זה גם מבטיח כיסוי עקבי וגם מקל על מבקר הסמכה להעריך את איכות התהליך:

- **PTES — Penetration Testing Execution Standard**: מסגרת מקיפה לכל שלבי המבדק (Pre-engagement, Intelligence Gathering, Threat Modeling, Vulnerability Analysis, Exploitation, Post-Exploitation, Reporting).
- **OWASP Testing Guide / OWASP Top 10**: הסטנדרט המוביל לבדיקת יישומי Web — רשימת קטגוריות החולשות הנפוצות ביותר (Injection, Broken Access Control, Cryptographic Failures וכו') ומתודולוגיית בדיקה מפורטת לכל אחת.
- **NIST SP 800-115** — "Technical Guide to Information Security Testing and Assessment": מסגרת אמריקאית רשמית, שימושית כשצריך ליישר קו עם דרישות רגולטוריות אמריקאיות מקבילות.

- **OSSTMM – Open Source Security Testing Methodology Manual**: מתודולוגיה מדידה-מבוססת (Risk Assessment Values) לבדיקות מקיפות יותר מווב לבד.
- **MITRE ATT&CK** – לא מתודולוגיית pentest קלאסית אלא מסגרת טקטיקות ותת-טכניקות אמיתיות של תוקפים; משמשת בעיקר לתכנון תרחישי Red Team ולמידת יכולת גילוי (Detection Coverage).

9.4 מ-Scoping ועד Retest – מיפוי לתהליך ה-ISMS

מחזור עבודה טיפוסי לבדיקת חדירה, ואיך כל שלב "נתפר" לתוך תהליך ה-ISMS:

1. **הרשאה כתובה ו-Rules of Engagement (ROE)** – לפני כל פעולה. ראו את `pentest-milatova/scope.md` ו-`pentest-booknet/scope.md` בריפו זה כדוגמאות ממשיות למסמך `scope`: הגדרת מטרה, מה מותר/אסור (ללא DoS, ללא כתיבה/מחיקה, ללא ניסיונות עקיפת אימות ללא אישור מפורש), וחשיפת הרשאה כתובה שנשמרת מחוץ למאגר הקוד אם היא רגישה. זה תואם ישירות לדרישות A.5.31 (דרישות משפטיות/חוזיות) ולעקרון "בדוק רק את מה שהורשית לבדוק".
2. **איסוף מודיעין וסריקה** – recon פסיבי/אקטיבי, זיהוי טכנולוגיות ונתיבי חשיפה.
3. **זיהוי וניצול חולשות** – בהתאם לגבולות ה-ROE (לדוגמה, `pentest-milatova` הוגבל ל-GET בלבד, ללא ניצול/brute-force בפועל – מה שהופך אותו ל"סקר פסיבי" יותר מ"מבדק חדירה מלא", והבחנה זו **חייבת** להופיע בדוח כדי שלא יוצג רושם שווא של עומק הבדיקה).
4. **דיווח (Reporting)** – כל ממצא מתועד עם: תיאור, חומרה, השפעה, שורש הבעיה, עדות (evidence), והמלצת תיקון. ראו את `pentest-milatova/findings/002-privileged-user-data-exposure.md` כדוגמה לדיווח מלא (Endpoint, Description, Root cause, Impact, Evidence, Remediation) – מבנה זה כמעט זהה למה שמבקר ISO יצפה לראות ברשומת סיכונים.
5. **תרגום ממצאים לסיכון וטיפול** – כאן ה-pentest "נכנס" רשמית ל-ISMS: כל ממצא ממופה לחולשה טכנית (לרוב CWE), מקבל ניקוד סיכון, ומוזן לתכנית טיפול בסיכונים (6.1.3) עם בעל סיכון ולוח זמנים. ראו סעיף 9.6 למטה – דוגמה מלאה שממירה את שני הממצאים האמיתיים מ-`pentest-milatova` לרשומת סיכונים בעזרת הכלי הנלווה לספר.
6. **תיקון (Remediation)** – פעולה מתקנת (10.2), עם אחראי ולוח זמנים לפי רמת הסיכון (למשל: Critical/High – ימים בודדים עד שבועות; Medium – עד רבעון; Low – מחזור התחזוקה הבא).
7. **בדיקה חוזרת (Retest)** – אימות שהתיקון אכן סגר את הפער – עדות קריטית להוכחת אפקטיביות הפעולה המתקנת (חלק מ-10.2), ולעיתים קרובות הדבר הראשון שמבקר יבקש לראות ("הראו לי לא רק את הממצא – הראו לי שהוא נסגר").

9.5 תדירות ו"טריגרים" ליישום pentest

התקן לא קובע תדירות מספרית, אך הפרקטיקה המקובלת (ומה שרוב גופי ההסמכה יצפו לראות כ"בסיס סביר" של ניהול סיכונים) היא:

- **לפחות אחת לשנה** לכל מערכת/שירות בהיקף ה-ISMS שחשף לאינטרנט או מעבד מידע רגיש.
- **לפני עלייה משמעותית לפרודקשן** — פיצ'ר מהותי חדש, שינוי ארכיטקטורה, מיזוג/רכישה של מערכת.
- **לאחר שינוי משמעותי בתשתית** — מעבר ענן, שדרוג גרסת פלטפורמה מהותית.
- **דרישה חוזית/רגולטורית** — לקוחות ארגוניים, PCI DSS (דורש במפורש pentest שנתי + אחרי שינוי מהותי), חוזי SaaS B2B.
- **כחלק מהכנה להסמכה ראשונית** — לפני Stage 2 (פרק 5), רצוי pentest שמכסה את היקף ה-ISMS המוצהר, כדי שממצאים לא יתגלו לראשונה על ידי המבקר.

9.6 דוגמה עובדת: מ-Pentest אמיתי לרשומת סיכונים

הריפו הזה כולל שני תיקי engagement אמיתיים — pentest-milatova/ ו-pentest-booknet/ — עם `scope.md`, `REPORT.md` וממצאים מתועדים. נשתמש בממצאי pentest-milatova כדוגמה מלאה למעבר מדוח pentest לרשומת סיכונים לפי מתודולוגיית ISO/IEC 27005 (פרק 4, סעיף 6.3 בפרק 6):

ממצא מקורי	חומרה בדוח	CWE ממופה
חשיפת שדות <code>context-edit</code> ו- <code>is_super_admin</code> ל- <code>anon</code> דרך <code>wp/v2/users</code>	High	CWE-862 — Missing Authorization (חסר <code>permission_callback</code>)
חשיפת <code>username/slug</code> דרך <code>wp/v2/users</code>	Low	CWE-200 — Exposure of Sensitive Information

```
python3 iso27001-book/tools/cwe_risk_calculator.py report \
--input iso27001-book/tools/pentest_case_study_findings.json
```

תוצאה:

cwe_id	name	likelihood	impact_max
asset	score	risk_level	

+-----+-----+-----			
CWE-862	Missing Authorization	milatova.org.il - wp-json/wp/v2/users (privileged edit-context fields)	4 4 16 גבוה (High)
CWE-200	Exposure of Sensitive Information to an Unauthorized Actor	milatova.org.il - wp-json/wp/v2/users (username/slug enumeration)	4 1 4 נמוך (Low)

1. **הממצא הראשון (CWE-862) מקבל אוטומטית מתוך טבלת ברירת המחדל של הכלי בדיוק את אותה רמת חומרה (High) שהמבקר האנושי קבע** — עדות לכך שממצא "פרצת הרשאות בממשק ציבורי" הוא מהותית High ברוב ההקשרים, בלי צורך בכיול מיוחד.
2. **הממצא השני (CWE-200) דרש דריסה ידנית (impact_c=1)** במקום ברירת המחדל (4) כדי לשקף שחשיפת username ב-WordsPress היא התנהגות מוכרת ולא-רגישה בפני עצמה — בלי הדריסה, הכלי היה מציג "High" באופן מוטעה. זו בדיוק הנקודה שהודגשה כבר בפרק 6 ובקובץ `tools/README.md`: **טבלת ה-CWE הבסיסית היא נקודת פתיחה להמחשה, לא תחליף לשיקול דעת אנושי בהקשר הספציפי של הממצא.**

9.7 עקרונות אתיים ומשפטיים — לא משא ומתן

- **אין לבצע כל פעולה פוגענית (exploitation, brute-force, DoS) ללא הרשאה כתובה ומפורשת** מבעל המערכת/הארגון, עם היקף מוגדר בכתב (מסמך scope/ROE חתום).
- **תיעוד ROE חייב לכלול:** מטרות מוגדרות, טווח IP/דומיינים מותרים, חלון זמן, אנשי קשר לעצירת חירום (Emergency Stop), מה אסור באופן מפורש (למשל: לא לבדוק זרימות תשלום אמיתיות, לא להשתמש בפרטי לקוחות אמיתיים).
- **הפרדת סביבות** — עדויות רגישות (תגובות גולמיות עם PII, אישורים שהתגלו) יש לשמור בנפרד, עם גישה מוגבלת, ולשקול לא לשמור אותן במאגר קוד משותף (ראו הערת ה-scope בקובצי `pentest-milatova/pentest-booknet` לגבי שמירת הסכם החתום מחוץ למאגר).
- **גילוי אחראי (Responsible Disclosure)** — כשמזוהה חולשה בתלות צד-שלישי (ספרייה, פלאגין) שלא בבעלות הארגון עצמו, יש לדווח לספק בערוץ מוגדר (`security.txt`, תוכנית bug bounty) לפני חשיפה ציבורית.
- **אסור לבלבל בין "אין הרשאה מפורשת לבדיקה אקטיבית" לבין "מותר הכול כי המידע ציבורי"** — גם מידע שנגיש טכנית (כמו endpoint ציבורי) עשוי להיות מחוץ להיקף אם ה-ROE לא הרשה זאת במפורש.

9.8 טעויות נפוצות בשילוב ISMS ו-Pentest

- **"עשינו pentest פעם, סימנו וי"** — pentest חד-פעמי בלי מחזוריות מקביל לביקורת פנימית חד-פעמית: לא עומד ברוח סעיף 9 (הערכת ביצועים מתמשכת).
- **דוח מרשים שנשאר במגירה** — ממצאים ללא בעל סיכון, ללא תאריך יעד, ללא Retest, הם ראייה נגד הארגון בביקורת ("זיהיתם את הבעיה וגם לא טיפלתם בה" גרוע יותר מ"לא בדקתם").
- **היקף (Scope) לא תואם ל-ISMS Scope** — pentest שבדק רק חלק קטן מהמערכות בתוך היקף ה-ISMS המוצהר משאיר "עיוורון" שהמבקר עלול לתפוס.
- **בלבול בין Vulnerability Scan ל-Pentest** — הצגת פלט כלי אוטומטי כ"בדיקת חדירה" בפני מבקר או הנהלה, בלי בדיקה/ניצול אנושי בפועל.
- **דירוג חומרה לא-מכיל** — הסתמכות עיוורת על ברירת מחדל גנרית (כמו טבלת CWE הבסיסית בכלי הנלווה) בלי לשקלל הקשר ארגוני אמיתי — ראו סעיף 9.6 לעיל.

9.9 סדר עדיפויות בזמן מוגבל

בדיקת חדירה כמעט תמיד מתבצעת תחת אילוץ זמן (חלון engagement קצוב), ולכן השאלה הפרקטית ביותר אינה "מה לבדוק" (התשובה — הכול שבתקציב הזמן מרשה) אלא **באיזה סדר**. העיקרון המנחה: לתעדף לא לפי "מה הכי מסובך טכנית" אלא לפי מה שנותן לתוקף את הדריסה הגדולה ביותר, הכי מהר — כלומר בדיוק אותו עיקרון $\text{Likelihood} \times \text{Impact}$ שהכלי הנלווה לספר מיישם (פרק 6.3, 9.6). סדר עדיפויות מומלץ, מהדחוף ביותר:

1. **בקרת גישה שבורה / הרשאות חסרות (Broken Access Control)** — נקודות קצה מנהליות או API-ים שאמורים לדרוש הרשאה ולא בודקים זאת בפועל. זוהי קטגוריית החולשה מספר 1 ב-OWASP Top 10, וזה בדיוק הממצא ה-High מ-`pentest-milatova` (CWE-862, סעיף 9.6) — חשיפת "מי הוא super-admin" נותנת לתוקף מפת דרכים מיידיית עוד לפני שניסה לפרוץ בפועל.
2. **הזרקות (Injection — SQLi, Command Injection)** — פחות שכיחות מבעבר, אך כשקיימות ההשפעה כמעט תמיד קריטית (CWE-89/CWE-78 בטבלת הכלי: impact 4-5 בכל שלושת צירי ה-CIA).
3. **סודות חשופים / קרדנציאלים קשיחים בקוד** (CWE-798/259/522) — לרוב הדרך המהירה ביותר להשתלטות מלאה, וזולה יחסית לאיתור (חיפוש בקוד, בהיסטוריית git, בקבצי קונפיגורציה) — שווה לבדוק מוקדם ב-engagement.
4. **טביעת אצבע גרסאות / CVE ידועים** — ראו את ממצא ה-Info ב-`pentest-milatova/REPORT.md`: חשיפת גרסת Yoast SEO ב-HTML comment. זו בדיקה זולה שיכולה לקצר משמעותית את שאר הבדיקה אם הגרסה חשופה ל-CVE ציבורי.
5. **חשיפת מידע רגיש / הצפנה חסרה** (CWE-200/CWE-311/CWE-319) — פחות "מפוצץ" אך נפוץ מאוד, ולעיתים מזין את השלבים הקודמים (למשל חשיפת username מזינה ניחוש קרדנציאלים, ראו הממצא ה-Low באותה דוגמה).

כלל אצבע לתעדוף: מה שחשוף לאינטרנט + לא דורש אימות מוקדם + מעניק הרשאות/מידע רחב-היקף מנצח כל חולשה תיאורטית שדורשת שרשרת תנאים ספציפית לניצול — בדיוק ההבדל בין ציון 16 ל-4 בדוגמה שבסעיף 9.6.

לחזרה לתוכן העניינים המלא — ראו [README.md](#). הפרק הבא (מונחים וצ'ק-ליסט) נמצא ב-[פרק 8](#).

כלים נלווים לספר

cwe_risk_calculator.py – מחשבון סקר סיכונים לפי CWE

כלי שורת-פקודה המפעיל אופליין לחלוטין (ללא רשת, ללא תלות בחבילות חיצוניות) המיישם מודל ניקוד סיכונים **Likelihood × Impact** (מטריצת 5×5), בהתאם למתודולוגיה המתוארת ב-ISO/IEC 27005 ומיושמת בסעיף 6.1.2 של ISO/IEC 27001 (ראו פרק 2 ו-פרק 6).

הכלי כולל טבלת בסיס קטנה ומתוחזקת-ידנית של חולשות **CWE** נפוצות (מבוססת בעיקרה על חולשות שחוזרות ברשימות "CWE Top 25 Most Dangerous Software Weaknesses"), עם הצעות ברירת-מחדל לסבירות ולהשפעה על סודיות/שלמות/זמינות לכל CWE. אלו **ערכי פתיחה להמחשה בלבד** – כל ארגון חייב לכייל אותם למציאות שלו (סוג הנכס, חשיפה, בקורות מפצות קיימות וכו') לפני שהם משמשים בפועל בהצהרת ההתאמה (SoA) או ברשומת הסיכונים הרשמית.

שימוש

```
# הבסיסית הכלולה בכלי CWE-הצגת טבלת ה
python3 cwe_risk_calculator.py list

# בודד, עם דריסת ברירת המחדל של הסבירות CWE ניקוד
python3 cwe_risk_calculator.py score --cwe CWE-89 --asset "פורטל לקוחות" --likelihood 3

# והפקת רשומת סיכונים ממוינת (CSV או JSON) ניקוד קובץ ממצאים שלם
python3 cwe_risk_calculator.py report --input sample_findings.json --output risk_register.csv
```

מבנה קובץ ממצאים (JSON או CSV) לפקודת `report`: שדה חובה `cwe_id`, ושדות אופציונליים `asset`, `likelihood`, `impact_c`, `impact_i`, `impact_a`, `notes` – כל שדה שלא סופק נלקח מטבלת ברירת המחדל של הכלי. דוגמה כללית ב-`sample_findings.json`, ודוגמה מבוססת על שני ממצאי `pentest` אמיתיים מתוך `pentest-milatova/` (בשורש הריפוי) ב-`pentest_case_study_findings.json` – ראו פירוט מלא בפרק 9 של הספר (9.6), כולל הסבר מדוע ממצא אחד דורש דריסה ידנית של ברירת המחדל כדי לשקף נכון את ההקשר.

מודל הניקוד

`score = likelihood (1–5) × max(impact_c, impact_i, impact_a) (1–5)`

טווח ציון	רמת סיכון
4–1	נמוך (Low)
9–5	בינוני (Medium)
16–10	גבוה (High)
25–17	קריטי (Critical)

מודל זה הוא דוגמה פדגוגית פשוטה ונפוצה, לא דרישה נורמטיבית של התקן — ISO/IEC 27005 משאיר את בחירת המתודולוגיה המדויקת לארגון, ובלבד שהיא עקבית וניתנת לשחזור (ראו סעיף 6.1.2 בפרק 2).

`build_book_pdf.py` — הפקת הספר כקובץ PDF יחיד

מרכיב את כל פרקי הספר (`tools/README.md` + `01 - 09` + `README.md`) כנספח לקובץ PDF אחד עם עימוד RTL תקין, תוכן עניינים מקושר (קישורים פנימיים בין הפרקים הופכים לעוגנים בתוך אותו PDF), טבלאות, ובלוקי קוד ב-LTR. דורש שתי תלויות אופציונליות שאינן חלק מהליבה של שאר הריפו:

```
pip install weasyprint markdown

python3 iso27001-book/tools/build_book_pdf.py
# כותב ל: iso27001-book/ISO-27001-Summary-Book-HE.pdf
```

הריצו מחדש בכל פעם שמעדכנים פרק, כדי שה-PDF המצורף יישאר מסונכרן עם קבצי ה-Markdown (מקור האמת של הספר).